

TenantProof

Executed tenant-boundary evidence for Supabase SaaS

Prove that Customer A cannot read or modify Customer B's data.

Product strategy, page specifications, UX system, technical architecture, safety boundaries, commercial model, roadmap, release state, and AI continuation protocol.

SNAPSHOT	2026-08-30
STAGE	Request-only soft launch; premium static deployment pending GitHub administrator reapproval
QUALITY	Full source, browser, privacy, documentation, media, and release quality gates passed
COMMERCIAL	\$349 verification / \$649 verification + repair; payments closed; no customers or revenue yet

This report contains no customer data, credentials, real findings, testimonials, or revenue claims. Northstar CRM is fictional.

Snapshot: 2026-08-30 **Product stage:** request-only soft launch; premium static deployment blocked by GitHub administrator reapproval **Commercial stage:** validated paid demand, no customer or revenue yet **Next model objective:** preserve product quality, complete repository publication, then run a ten-buyer paid-pilot experiment

Executive summary

TenantProof is a productized service for founders launching multi-tenant SaaS applications on Supabase/PostgreSQL. It executes a buyer-approved authorization matrix and produces redacted before/after evidence. The winning wedge is not “we enabled RLS”; it is “we proved the tenant and role boundaries that matter to your application.”

The product exists as a polished local static website, interactive fictional report viewer, local scope worksheet, versioned report schema, demo-only runner, production hardening, operational templates, and a public Notion qualification path. The premium GitHub Pages release has not been pushed because the GitHub connection requires administrator reapproval.

Why this product was selected

The project began with a broad goal: launch any product or service capable of earning at least \$100 within ten days. Multiple concepts were built or considered. The user rejected ideas that were easy to DIY, low urgency, aesthetically weak, or replaceable by generic AI/design labor.

Buyer-first research found recent paid requests for:

- a \$300 Supabase authorization review
- a \$500 Lovable/Supabase security audit
- a \$700 pre-launch Supabase/PostgreSQL review
- urgent repair of a real cross-tenant data leak
- recurring multi-tenant RLS implementation and audit work

TenantProof won because one legitimate engagement clears the revenue target, the risk is launch-critical, the deliverable is concrete, and generic AI cannot prove application-specific role semantics without executing the agreed controls.

Product thesis

A scanner can detect missing RLS, broad policies, exposed functions, or public buckets. It cannot determine by itself whether a manager may see another team’s records, whether a coach may see an unassigned client, or whether a function preserves the same role semantics as the UI.

TenantProof turns those semantics into an explicit matrix:

`actor × tenant × resource × operation × expected result`

It then records the observed result, evidence, remediation, and retest status. The buyer receives an engineering decision artifact rather than a green badge.

Implemented product

Public site

- `index.html` — category framing, problem, evidence preview, method, pricing, boundaries, CTA

- `report.html` — interactive sample/local report viewer
- `methodology.html` — authorization and evidence method
- `request.html` — three-step local scope brief builder
- `privacy.html` — current pre-release privacy notice
- `terms.html` — current pre-release terms and limitations
- `404.html` — branded recovery route

Product logic

- responsive navigation
- progressive reveal with reduced-motion fallback
- configuration-driven preview/ready state
- package selection through query parameters
- non-submitting local scope wizard
- copy and text-download brief actions
- local JSON report import with 2 MB limit
- report schema validation
- before/after phase comparison
- actor, area, operation, status, and text filters
- keyboard-selectable evidence rows
- printable report
- fictional demo runner locked against live mode

Production preparation

- restrictive meta CSP on all HTML pages
- portable `_headers`
- canonical, Open Graph, and Twitter metadata
- sitemap, robots, manifest, `.nojekyll`, `llms.txt`
- 192/512 icons and 1200×630 social preview
- external runtime configuration
- release-readiness checker
- authorization, SOW, evidence, delivery, payment, intake, launch, marketing, and GitHub runbooks

Public soft-launch surfaces

- public Notion qualification form with anonymous submission and no response visibility
- private Notion intake database with table and pipeline views
- public Notion launch page
- public fictional sample report

- synthetic end-to-end form submission completed and deleted

Current quality result

Last completed browser QA:

- 22 required public files
- 7 HTML pages loaded
- 7 CSP-compatible pages
- 16 sample checks
- before: 11 pass, 4 fail, 1 unresolved
- after: 15 pass, 0 fail, 1 unresolved
- status filtering passed
- local report import passed
- local scope wizard passed
- mobile navigation passed
- no mobile overflow
- no console errors
- no external runtime requests
- no browser persistence or POST requests
- demo runner rejects non-demo mode

Do not treat this snapshot as permanent. Run `npm run quality` after every material change.

Design direction

The visual system is intentionally premium, calm, and technical:

- deep ink and forest surfaces
- warm paper and off-white content areas
- restrained mint green as proof/positive accent
- red and amber reserved for evidence states
- large editorial headlines paired with compact evidence UI
- system fonts only
- generous spacing, strong hierarchy, minimal decoration
- no stock imagery, fake logos, or noisy security clichés

The design should feel like a trusted engineering dossier, not a hacker landing page or generic SaaS template.

Commercial model

- Boundary Verification: \$349

- Verification + Repair: \$649
- larger/sensitive scope: manual quote
- request-only launch
- no unrestricted checkout
- recommended payment: operator-issued Stripe invoice after qualification and signed scope
- repair package can use two \$324.50 milestones
- raw evidence default: 14 days after accepted delivery

Payment stays closed until a real legal contracting party, jurisdiction, owned business contact, processor, tax/refund position, and delivery capacity are configured.

Current blockers

- 1 GitHub MCP operations require administrator reapproval.
- 2 Current repository `main` must be freshly inspected; historical SHAs are not authority.
- 3 Owned business email and final legal operator identity are not configured.
- 4 Premium site config remains in preview state.
- 5 Static privacy/terms still contain pre-launch language.
- 6 No `.well-known/security.txt` until an owned security contact exists.
- 7 No payment processor is connected.

Immediate continuation plan

- 1 Finish and validate this handoff package.
- 2 Reconnect GitHub and call `get_me`.
- 3 Inspect current `main`, workflow, source directory, and PR template.
- 4 Reconcile the local release with repository reality; do not blind-overwrite.
- 5 Commit product source, `AGENTS.md`, `handoff/`, operations, and build tooling.
- 6 Ensure production deployment publishes only `public/`; test sources and generated logs stay out of the web artifact.
- 7 Run full quality gate and inspect screenshots/video.
- 8 Merge after checks; user explicitly authorized autonomous merging.
- 9 Verify live routes, CSP, intake CTA, sample report, print, and mobile behavior.
- 10 Run the ten-prospect experiment through an authenticated approved account; do not use the private Outlook address for cold outreach.

Mindset to preserve

- Buyer evidence before more features.
- Narrow and provable beats broad and impressive-sounding.

- Trust is created by limits, evidence, and operational discipline.
- A failed check is useful; an untested check is not a pass.
- One paid pilot matters more than traffic.
- Do not build a scanner dashboard, account system, or recurring SaaS until a buyer proves the need.
- Compete by making the purchase safer and the output more decision-useful, not by claiming all competitors are dead.

Historical context

Rebuttalkit

A previous revenue product was technically built and deployed but commercially rejected. It was frozen with checkout closed. Do not reuse its live site as proof of TenantProof.

Stay5

A habit/behavior product was completed locally but commercially rejected and never deployed. Frozen.

App Store screenshot service / ClearCal

Rejected because buyers can use templates, AI, or inexpensive designers; the proposed price lacked durable value. No proposal was submitted.

Relay migration and related shutdown services

Considered but rejected because reachable demand and differentiated fulfillment were weaker than TenantProof.

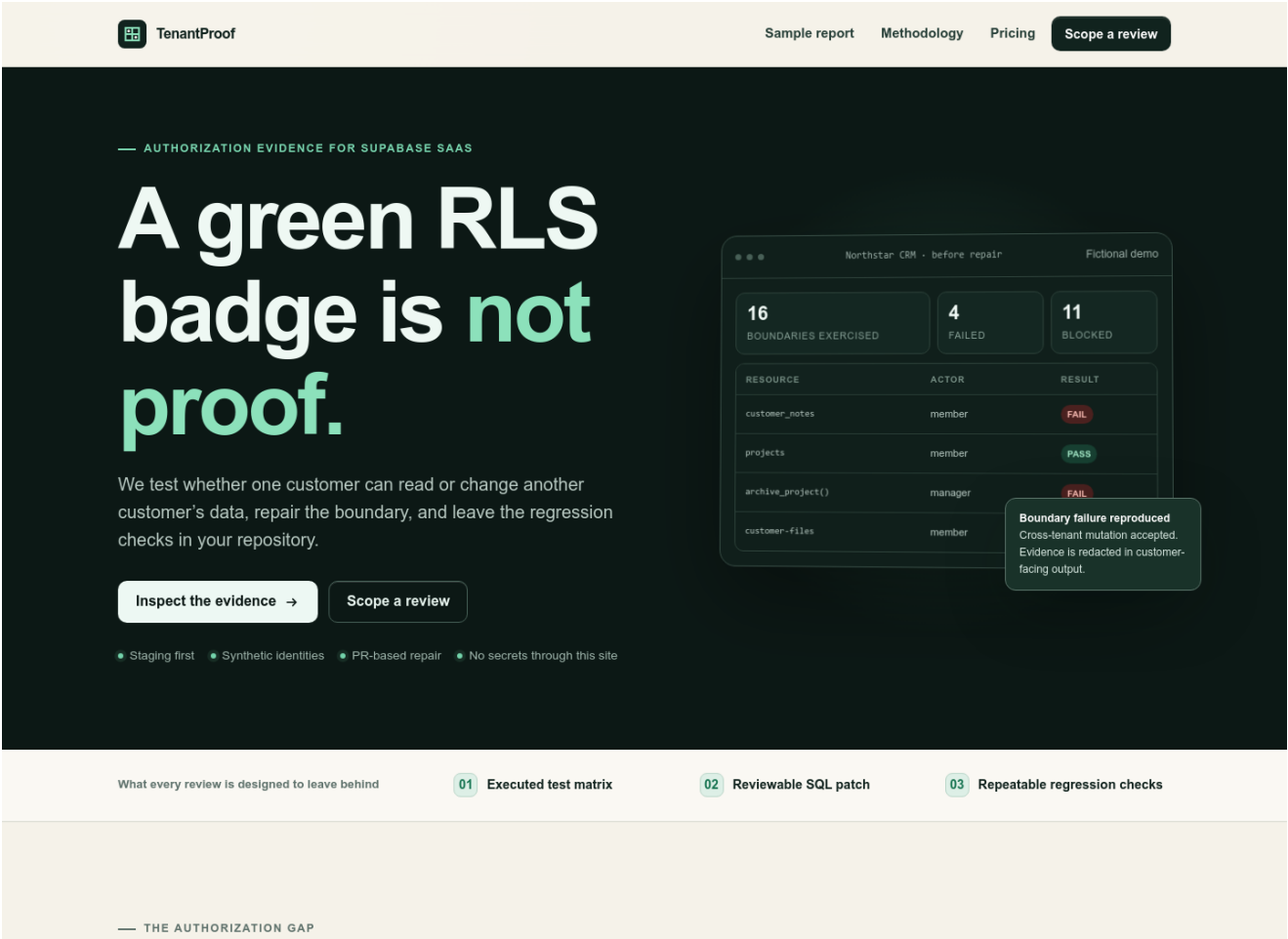
Full lessons are in REJECTED_IDEAS_AND_LEARNINGS.md.

Handoff integrity statement

This folder records strategy, implementation, decisions, limitations, and state. It does not contain customer secrets, production credentials, private data, or claims of work that did not happen. Any future agent must preserve that standard.

Visual product reference

These images define the intended production quality. They are generated from the local fictional product and contain no customer evidence.



Desktop first viewport — category, evidence preview, and primary actions

TenantProof / Report viewer

— LOCAL-FIRST DELIVERABLE

Every conclusion should point to an executed check.

Explore the fictional report, compare before and after, or open a compatible redacted JSON report entirely inside your browser.

Open a TenantProof JSON report

Processed in this browser tab. The file is not uploaded or stored.

Choose report

Northstar CRM

TP-DEMO-0030 • Fictional staging demo

FICTIONAL DEMO

Desktop report viewer — local import, matrix controls, and evidence shell

TenantProof

TenantProof / Scope a review

PRIVATE LOCAL WORKSHEET

Describe the boundary. Keep the secrets.

This pre-launch form creates a review brief in your browser. It does not transmit the contents or authorize testing.

Package

Application

Private brief

STEP 1 OF 3

Choose the starting scope

Final scope is confirmed before payment or access.

Boundary Verification · \$349

Up to 12 tables, three roles, executed matrix, findings, and one retest.

Verification + Repair · \$649

Up to 25 tables, selected functions and storage, patches, regression checks, and one retest.

Review pricing

Describe application

NEVER PUT THESE IN THE BRIEF

Credentials belong in a separate, approved access process.

- Supabase service-role keys or database passwords
- Production customer records or database exports
- Personal information not necessary for scoping
- Credentials for GitHub, hosting, billing, or analytics
- A third party's target without written authorization

TenantProof

Evidence-driven tenant-boundary verification and repair for Supabase applications.

PRODUCT

[Sample report](#)[Methodology](#)[Pricing](#)

TRUST

[Privacy](#)[Terms](#)

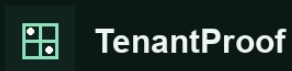
START

[Scope a review](#)

© 2026 TenantProof. Pre-launch preview.

This form does not transmit data.

Mobile scope worksheet — package, application surface, and non-sensitive brief



A green RLS badge is not proof.

Executed tenant-boundary evidence for Supabase SaaS.

BOUNDARY MATRIX

16

CHECKS

4

FAILED

11

BLOCKED

customer_notes

FAIL

projects

PASS

archive_project()

FAIL

customer-files

PASS

1200×630 social-preview asset

Canonical source index

The PDF is a reviewable snapshot. The Markdown/JSON files below remain the editable source of truth.

- AGENTS.md
- handoff/HANDOFF_REPORT.md
- handoff/CURRENT_STATE.json
- handoff/PRODUCT_SPEC.md
- handoff/PAGE_AND_SECTION_SPECS.md
- handoff/UX_DESIGN_SYSTEM.md
- handoff/TECHNICAL_ARCHITECTURE.md
- handoff/FEATURE_AND_FUNCTION_INVENTORY.md
- handoff/REPORT_ENGINE_SPEC.md
- handoff/SECURITY_PRIVACY_AND_SAFETY.md
- handoff/OPERATIONS_AND_INTAKE.md
- handoff/COMMERCIAL_AND_PAYMENTS.md
- handoff/GTM_AND_VALIDATION.md
- handoff/ROADMAP_V1_V2_V3.md
- handoff/DECISION_LOG.md
- handoff/REJECTED_IDEAS_AND_LEARNINGS.md
- handoff/QUALITY_GATES.md
- handoff/RELEASE_AND_REPOSITORY.md
- handoff/ASSET_MANIFEST.md
- handoff/AI_CONTINUATION.md

Continuation rule

A future agent reads AGENTS.md first, validates CURRENT_STATE.json against the repository, runs the quality gate, and updates the handoff whenever behavior or decisions change.